AI AGENT MONITOR
tích hợp Anti-Bot Pro

Hệ thống giám sát AI Agent giao dịch FX và thanh toán
(chuyển tiền · mua sắm online · thẻ Visa / Mastercard)

Tài liệu nguyên tắc thiết kế và hướng dẫn vận hành chi tiết

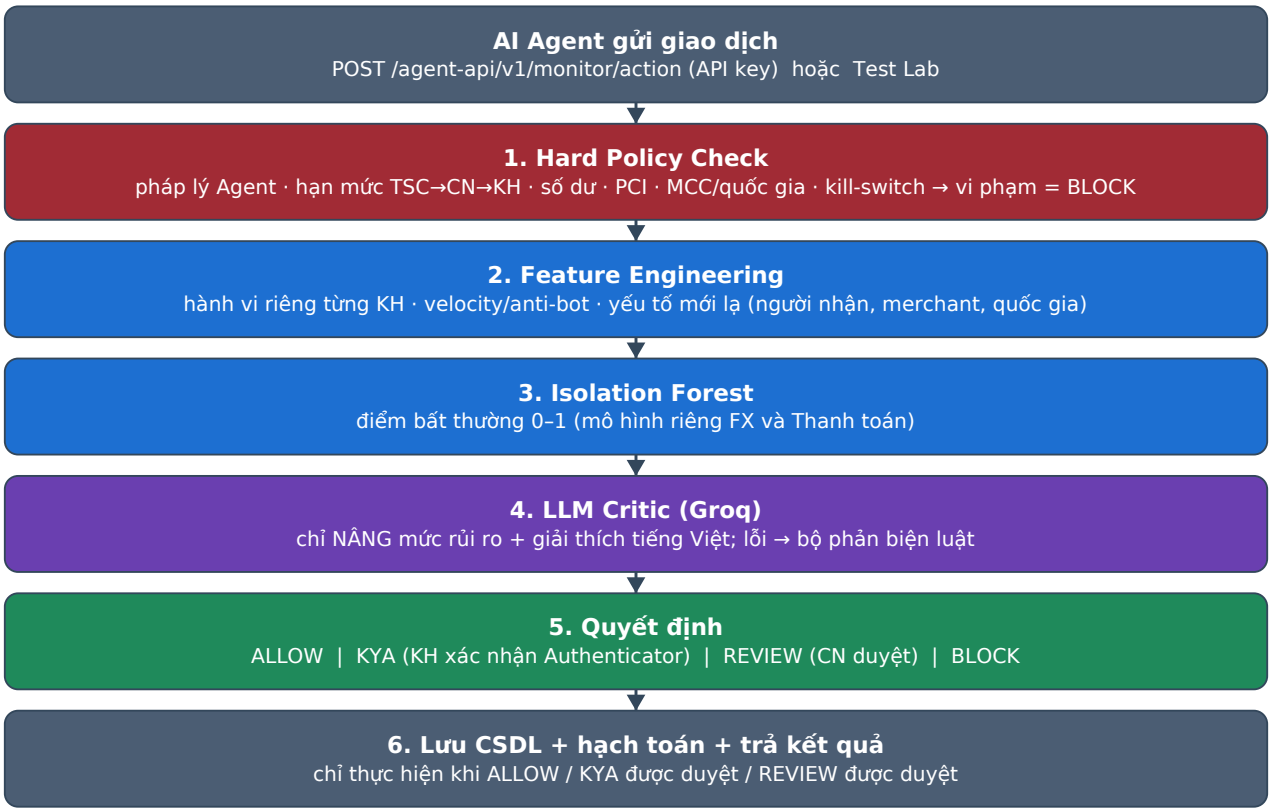
Thành phần	Nội dung
Nền tảng	Anti-Bot Pro v2 (Flask) – đăng nhập, phiên, CSRF, rate-limit, 3 cổng TSC / Chi nhánh / Khách hàng
Module mới	agentmon – 2 phân hệ độc lập: FX Trading và Thanh toán; Isolation Forest; LLM Critic (Groq); KYA/Authenticator; Test Lab
Phiên bản	1.0 (demo/pilot) – 82 test tự động đạt (62 gốc + 20 mới)
Đối tượng đọc	Quản trị TSC, quản trị/nhân viên chi nhánh, khách hàng, đội kỹ thuật triển khai

1. Mục tiêu và nguyên tắc cốt lõi

Hệ thống hợp nhất **Anti-Bot Pro** (bảo vệ đăng nhập/giao dịch, phân quyền TSC → Chi nhánh → Khách hàng) với **AI Agent Monitor** (giám sát hành vi của phần mềm AI thực hiện giao dịch thay mặt khách hàng) thành **một hệ thống duy nhất**: một trang đăng nhập, một CSDL phiên, ba cổng theo vai trò, mỗi cổng có thêm các tab AI Agent.

- **Hai phân hệ tách biệt:** (1) **FX Trading** – kiểm soát hạn mức giao dịch và hành vi giao dịch; (2) **Thanh toán** – kiểm soát hạn mức và hành vi chuyển tiền, mua sắm online, thanh toán thẻ Visa/Mastercard. Mỗi phân hệ có chính sách, mô hình ML, tab Monitor và kịch bản test riêng.
- **Hard policy trước, ML sau:** các giới hạn cứng (hạn mức, số dư, pháp lý Agent, PCI) quyết định BLOCK ngay và **không thể bị ML/LLM ghi đè**.
- **Hành vi so với chính khách hàng đó:** điểm bất thường tính theo lịch sử riêng của từng khách (giá trị, giờ, người nhận, merchant, quốc gia, đòn bẩy…), không dùng ngưỡng chung cho tất cả.
- **Pháp lý Agent:** khách hàng phải **đăng ký Agent với ngân hàng** (đồng ý điều khoản, có Authenticator); chi nhánh duyệt và đặt hạn mức. Agent chưa duyệt = bị chặn hoàn toàn.
- **KYA (Know Your Agent) bằng Authenticator:** giao dịch bất thường – ví dụ khách chưa từng giao dịch online nay đột ngột giao dịch – được đẩy tới ứng dụng Authenticator để **khách duyệt trước khi thực hiện**.
- **Fail-closed:** cần KYA mà khách chưa có Authenticator → BLOCK; LLM lỗi → dùng bộ phản biện luật; quá nhiều KYA chờ → BLOCK (chống dội thông báo).

2. Kiến trúc và luồng xử lý



Mọi giao dịch của Agent đi qua **cùng một hàm engine.evaluate()** dù đến từ API key (Agent thật) hay từ Test Lab (demo) – nên kết quả test phản ánh đúng hành vi hệ thống thật.

Tầng	Thành phần	Vai trò
Giao diện	templates/portal_*.html, static/js/agentmon.js	Tab AI Agent trong 3 cổng + trang /authenticator

Tầng	Thành phần	Vai trò
API phiên	/api/agent/* (agentmon/api.py)	Dùng chung đăng nhập, CSRF, fingerprint, rate-limit của Anti-Bot; phân quyền theo vai trò và phạm vi KH
API Agent	/agent-api/v1/* (Bearer API key)	Cho AI Agent thật; rate-limit riêng; không lộ điểm rủi ro
API Authenticator	/authapp/* (Bearer device token + PIN)	Ghép thiết bị, liệt kê và duyệt/từ chối giao dịch chờ KYA
Lõi	engine · policy · features · ml · critic · kya · registry · cards	Pipeline quyết định, hạn mức phân cấp, đăng ký pháp lý, tuân thủ thẻ
Dữ liệu	SQLite WAL (data/agentmon.db)	Production: PostgreSQL (cùng schema). Mô hình ML: models/*.joblib

3. Vai trò, phạm vi và tài khoản demo

Vai trò	Phạm vi dữ liệu	Quyền chính với AI Agent
TSC (HQ)	Toàn hệ thống	Đặt chính sách/trần FX và Thanh toán theo phân khúc; ngưỡng KYA/REVIEW/BLOCK; danh sách MCC/quốc gia cấm; kill-switch; huấn luyện lại ML; xem mọi Monitor
Admin chi nhánh (CN_ADMIN)	KH của chi nhánh	Duyệt/từ chối đăng ký Agent; đặt hạn mức theo CIF (≤ trần TSC); đình chỉ/khôi phục Agent; khóa thẻ; duyệt giao dịch REVIEW; xóa cờ theo dõi
Nhân viên (PNV)	Các KH được phân công	Xem Monitor và hồ sơ hành vi; duyệt/từ chối hàng chờ REVIEW; không đổi hạn mức, không duyệt đăng ký
Khách hàng (CUSTOMER)	Chỉ chính mình	Đăng ký Agent; Authenticator; duyệt/từ chối KYA; hạ hạn mức; cấp API key; quản lý thẻ & người nhận tin cậy; Test Lab cho chính mình. Không thấy điểm ML/LLM

Tài khoản (mật khẩu demo123)	Gợi ý dùng
hq01	TSC: chính sách, kill-switch, mô hình
admin_cn01 / admin_cn02	Admin CN001 (CUST001,003,004,005,008) / CN002 (CUST002,006,007,009,010)
staff01 (CUST001, CUST003) · staff02 · staff03	Nhân viên chi nhánh – duyệt REVIEW
cust001	VIP – FX Agent + Payment Agent đang hoạt động (kịch bản FX-xx, PAY-xx chuẩn)
cust002	Doanh nghiệp – Treasury Bot FX+PAY (CN002)
cust003	Chuẩn – tài khoản ngủ đông 110+ ngày (kịch bản PAY-07)
cust004	Chuẩn – chỉ có lịch sử quầy, chưa từng online; Agent đang PENDING (luồng đăng ký + FIRST_ONLINE)
cust005	VIP – Quant Bot FX+PAY, đòn bẩy cao

4. Phân hệ FX Trading – nguyên tắc kiểm soát

Agent gửi lệnh FX: `domain=FX, kind=FX_TRADE, pair, side, notional_usd, leverage`. Quy đổi VND theo tỷ giá tham chiếu USD/VND trong chính sách (mặc định 26.200).

4.1 Hard policy (BLOCK ngay, không ML)

- Kill-switch TSC đang bật; Agent chưa đăng ký / PENDING / REJECTED / bị đình chỉ / KH tạm dừng / thu hồi / hết hạn hiệu lực.
- Agent không được đăng ký cho FX; CIF không ACTIVE hoặc chưa được chi nhánh bật dịch vụ online.
- Cặp tiền ngoài danh mục được phép (giao của TSC phân khúc ∩ CN ∩ Agent).
- Đòn bẩy vượt trần; giá trị lệnh vượt hạn mức/lệnh; cộng dồn trong ngày vượt hạn mức ngày (tính cả lệnh đang chờ KYA/REVIEW).

- Vượt số lệnh/giờ hoặc /ngày; ngoài khung giờ Agent được phép (nếu cấu hình).
- **Ký quỹ (notional ÷ đòn bẩy) vượt số dư tiền gửi thanh toán khả dụng** – số dư khả dụng đã trừ phần giữ chỗ cho giao dịch chờ.

4.2 Hành vi giao dịch được chấm điểm

- Giá trị so với trung bình lịch sử của chính khách (tỷ lệ, z-score); giờ lệch thói quen; cặp tiền chưa từng giao dịch; đòn bẩy tăng đột biến so với thói quen.
- Velocity/anti-bot: số lệnh trong 5 phút/giờ/24h, nhịp gửi lệnh đều bất thường, lệnh sát trần hạn mức, đã bị chặn nhiều lần.
- Dùng quá 70% số dư khả dụng; tài khoản ngủ đông; khách chưa từng giao dịch online/agent; Agent đang thử việc (3 giao dịch đầu luôn cần KYA).

5. Phân hệ Thanh toán – nguyên tắc kiểm soát

Ba loại giao dịch: **TRANSFER** (chuyển tiền), **ONLINE_PURCHASE** (mua sắm online – CNP), **CARD_PAYMENT** (thanh toán thẻ). Agent chỉ gửi **token thẻ** do ngân hàng cấp.

5.1 Hard policy

- Pháp lý Agent, kill-switch, CIF online (như FX); Agent phải được đăng ký cho đúng loại giao dịch.
- **Vượt số dư tiền gửi thanh toán khả dụng** → BLOCK (hành vi rút vượt số dư).
- Chuyển tiền: vượt hạn mức/lần, /ngày, /tháng; tài khoản thụ hưởng trong danh sách chặn.
- Thẻ/online: token không hợp lệ hoặc không thuộc khách; thẻ không ACTIVE/hết hạn; thẻ chưa bật online (CNP) hoặc quốc tế; vượt hạn mức thẻ/GD và /ngày; vượt hạn mức thanh toán thẻ/ngày của KH; MCC bị cấm (mặc định 7995 cờ bạc, 6051 tiền mã hóa/quasi-cash); quốc gia bị cấm vận.
- **PCI-DSS:** payload chứa số thẻ đầy đủ (dãy 13–19 số qua Luhn) hoặc trường nhạy cảm (cvv/cvc/pin/track...) → BLOCK + che dữ liệu trước khi lưu/ghi log.

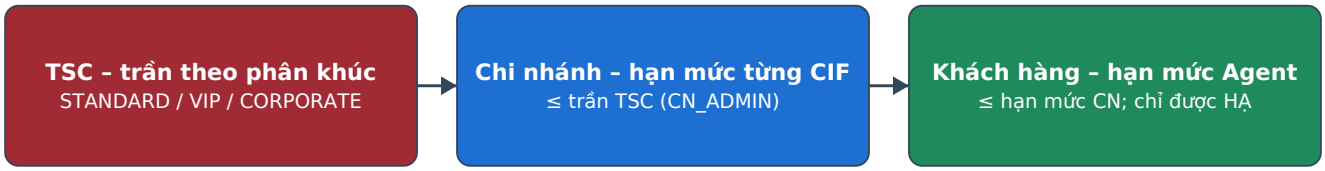
5.2 Quy định số thẻ Visa / Mastercard (mô phỏng PCI-DSS)

Quy tắc	Cách hệ thống thực thi
Nhận dạng mạng thẻ	Visa: bắt đầu bằng 4, dài 13/16/19. Mastercard: 51–55 hoặc 2221–2720, dài 16. Mạng khác bị từ chối.
Kiểm tra Luhn	Sai Luhn → từ chối đăng ký thẻ
Không lưu PAN	Chỉ lưu BIN6 + 4 số cuối + token + băm HMAC (chống trùng thẻ). PAN bị hủy ngay sau khi token hóa
Che số khi hiển thị	Tối đa 6 đầu + 4 cuối, ví dụ 4111 11** **** 1111
Không bao giờ nhận CVV/PIN	Trường nhạy cảm trong payload của Agent bị chặn và thay bằng [REDACTED]
Token hóa	Agent dùng token (tok_...) – lộ token không lộ số thẻ; chỉ dùng được với đúng KH và đúng trạng thái thẻ
3-D Secure	CNP không 3DS và giá trị ≥ ngưỡng (mặc định 5 triệu) → bắt buộc KYA
Dải test	Demo dùng số thẻ test: 4111111111111111, 4242424242424242, 5555555555554444, 5105105105105100, 2223003122003222

5.3 Hành vi được chấm điểm

- Người thụ hưởng mới; merchant mới; quốc gia mới hoặc rủi ro cao; MCC rủi ro cao; CNP không 3DS; giá trị gấp nhiều lần mức trung bình *của loại giao dịch đó* (chuyển khoản và thẻ có baseline riêng).
- Dò thẻ (card testing): ≥5 giao dịch < 50.000đ trong 10 phút; tách nhỏ/né hạn mức (số tiền 90–99,9% hạn mức); số tiền tròn triệu bất thường; rút ≥70% số dư; tài khoản ngủ đông; khách lần đầu online.

6. Hạn mức phân cấp TSC → Chi nhánh → Khách hàng



Hạn mức hiệu lực = MIN(TSC, Chi nhánh, Agent) – hard policy dùng giá trị này, ML/LLM không ghi đè

Giống mô hình cấu hình của Anti-Bot: TSC đặt **trần theo phân khúc**; Admin chi nhánh đặt **hạn mức từng CIF** (không được vượt trần – hệ thống từ chối với mã LIMIT_EXCEEDS_TSC); khách hàng đề nghị hạn mức khi đăng ký Agent (chi nhánh duyệt và hệ thống tự kẹp ≤ trần) và sau đó **chỉ được hạ**, muốn nâng phải qua chi nhánh. Thay đổi trần của TSC có hiệu lực ngay cho hạn mức hiệu lực.

6.1 Trần mặc định FX

Chỉ tiêu	STANDARD	VIP	CORPORATE
Hạn mức / lệnh (USD)	20,000	100,000	500,000
Hạn mức / ngày (USD)	60,000	400,000	2,000,000
Đòn bẩy tối đa (x)	10	20	10
Số lệnh / giờ	10	20	30
Số lệnh / ngày	40	120	200
Cần KYA từ (USD)	8,000	50,000	300,000
Cặp được phép	USDVND, EURVND, EURUSD, GBPUSD, USDJPY	11 cặp (toàn bộ)	11 cặp (toàn bộ)

6.2 Trần mặc định Thanh toán (VND)

Chỉ tiêu	STANDARD	VIP	CORPORATE
Chuyển tiền / lần (VND)	50,000,000	500,000,000	5,000,000,000
Chuyển tiền / ngày (VND)	200,000,000	2,000,000,000	20,000,000,000
Chuyển tiền / tháng (VND)	1,000,000,000	10,000,000,000	200,000,000,000
Thẻ / giao dịch (VND)	30,000,000	200,000,000	500,000,000
Thẻ / ngày (VND)	100,000,000	500,000,000	2,000,000,000
Mua sắm online / lần (VND)	20,000,000	100,000,000	500,000,000
Số lệnh / giờ	15	30	60
Số lệnh / ngày	60	150	400
Cần KYA từ (VND)	10,000,000	50,000,000	2,000,000,000
Người nhận mới cần KYA từ (VND)	2,000,000	10,000,000	50,000,000

6.3 Tham số chung

Tham số	Mặc định	Ý nghĩa
kya_threshold / review_threshold / block_threshold	0.35 / 0.65 / 0.85	Điểm rủi ro tổng hợp từ ngưỡng nào thì KYA / REVIEW / BLOCK (phải tăng dần)
kya_ttl_seconds	180	Thời gian khách có để duyệt KYA; quá hạn → giao dịch bị hủy, không thực hiện

Tham số	Mặc định	Ý nghĩa
max_pending_kya	5	Số KYA chờ tối đa/KH; vượt → BLOCK (chống dội thông báo)
probation_actions	3	Số giao dịch đầu của Agent mới luôn cần KYA
dormant_days	60	Số ngày không hoạt động để coi là ngủ đông
balance_drain_pct	0.7	Giao dịch dùng ≥ tỷ lệ này của số dư khả dụng → KYA
cnp_3ds_above_vnd	5,000,000	CNP không 3DS từ mức này → KYA
blocked_mcc / high_risk_mcc	7995, 6051 / 5967, 5816, 6540, 4829, 6012	MCC cấm (BLOCK) / MCC rủi ro (KYA)
blocked_countries / high_risk_countries	KP, IR, SY, CU / NG, RU, BY, MM, VE, PK	Danh sách mẫu để demo – cấu hình theo chính sách tuân thủ thật của ngân hàng

7. Chấm điểm và quyết định

Sau khi qua hard policy, hệ thống tính ba điểm 0–1 rồi hợp nhất:

```
anomaly   = Isolation Forest (chu□n hóa theo phân vị 50% → 99,5% c□a dữ liệu hu□n luyện)
behavior  = t□ng đi□m lệch hành vi so với lịch s□ RIÊNG c□a khách (có gi□i thích từng lý do)
velocity  = t□ng đi□m t□c độ/anti-bot (burst, dò th□, né hạn mức, bị chặn nhi□u l□n)
raw   = 0,40·anomaly + 0,30·behavior + 0,30·velocity
final = 0,70·raw + 0,30·max(behavior, velocity)      (+0,10 n□u KH đang trong watchlist)
# ML đơn độc không kéo đi□m lên – c□n tín hiệu hành vi/velocity đ□ng thuận
```

Điều kiện (xét theo thứ tự)	Quyết định	Hệ quả
Vi phạm hard policy	BLOCK	Không thực hiện; lý do hiển thị cho KH/Agent
final ≥ block_threshold	BLOCK	Không thực hiện; tăng suspicion của KH
final ≥ review_threshold	REVIEW	Giữ chỗ số dư; chờ nhân viên CN duyệt/từ chối
final ≥ kya_threshold **hoặc** có trigger KYA	KYA	Gửi Authenticator; chỉ thực hiện khi KH duyệt trong thời hạn
Còn lại	ALLOW	Thực hiện ngay, trừ số dư
LLM Critic khuyến nghị cao hơn	Nâng 1 mức (tối đa REVIEW)	LLM không bao giờ hạ mức, không tạo BLOCK, không ghi đè hard policy

Trigger bắt buộc KYA (xác định, không phụ thuộc ML)

Mã	Điều kiện
FIRST_ONLINE	Khách chưa từng có giao dịch online/agent đã thực hiện – nay phát sinh lần đầu
DORMANT_WAKE	Không giao dịch ≥ dormant_days rồi bỗng giao dịch
AMOUNT_OVER_KYA	Giá trị ≥ ngưỡng 'cần KYA' hiệu lực
NEW_BENEFICIARY	Người nhận mới (chưa từng chuyển, chưa trong danh sách tin cậy) và số tiền ≥ ngưỡng người nhận mới
NO_3DS / NEW_COUNTRY / HIGH_RISK_COUNTRY / HIGH_RISK_MCC	Thẻ: không 3DS vượt ngưỡng, quốc gia mới hoặc rủi ro, ngành hàng rủi ro
BALANCE_DRAIN	Dùng ≥ 70% số dư khả dụng
LEVERAGE_SPIKE	FX: đòn bẩy > 10x và gấp > 2,5 lần thói quen
AGENT_PROBATION	Agent mới: N giao dịch đầu
CARD_TESTING	≥5 giao dịch rất nhỏ trong 10 phút

Mô hình ML

Hai mô hình Isolation Forest (FX: 21 đặc trưng; Thanh toán: 31 đặc trưng) được huấn luyện trên dữ liệu tổng hợp (≈9.000 mẫu/mô hình, 40% khách giả lập là 'mới lên online', có hành vi lành tính hiếm gặp như người nhận mới, số tiền tròn) **bằng chính hàm feature của hệ thống**. Với khách bình thường, kiểm tra hiệu chỉnh cho thấy ≈ 97% giao dịch đúng thói quen được ALLOW. Trong production cần huấn luyện lại bằng lịch sử thật (HQ → tab Model & LLM, hoặc `python -m agentmon.train_cli`).

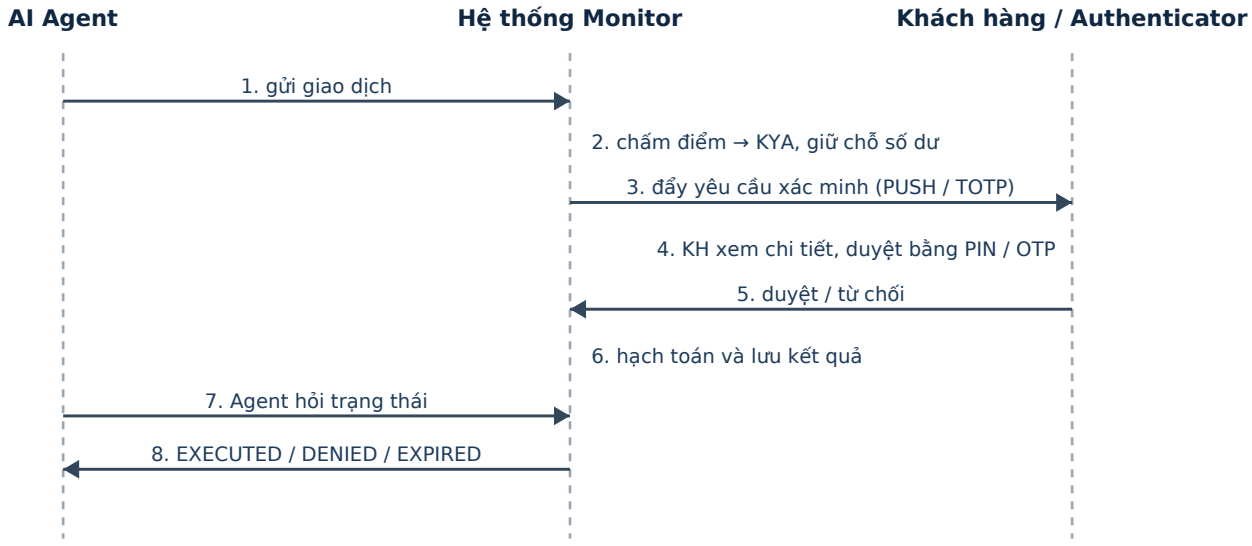
8. Đăng ký Agent (pháp lý) và KYA / Authenticator

8.1 Vòng đời đăng ký Agent

Bước	Ai	Nội dung
1	Khách hàng	Tab 'Authenticator & KYA': tạo mã ghép nối + secret TOTP (điều kiện bắt buộc)
2	Khách hàng	Tab 'AI Agent của tôi': khai tên, mục đích, nghiệp vụ (FX/PAY), hạn mức đề nghị; **đọc và tích đồng ý điều khoản pháp lý**; nhập OTP → hồ sơ PENDING (lưu phiên bản điều khoản, thời điểm, IP, mã băm điều khoản)
3	Admin CN	Tab 'Duyệt Agent': duyệt (đặt hạn mức, tự kẹp ≤ trần TSC) hoặc từ chối kèm lý do → ACTIVE (hiệu lực mặc định 365 ngày)
4	Khách hàng	Tự cấp API key (cần OTP) – hiển thị một lần; cấp lại sẽ vô hiệu khóa cũ. Admin CN không bao giờ thấy khóa
5	Agent	Gọi API bằng Bearer key; 3 giao dịch đầu cần KYA (thử việc)
6	Mọi bên	Tạm dừng (KH), đình chỉ/thu hồi (CN/TSC). KH từ chối KYA 3 lần → hệ thống tự đình chỉ Agent

Trạng thái Agent: PENDING → ACTIVE ⇄ PAUSED (KH) / SUSPENDED (ngân hàng) → REVOKED (vĩnh viễn). Bị REJECTED nếu CN từ chối. Chỉ ACTIVE và còn hiệu lực mới được giao dịch.

8.2 Luồng KYA



Kênh xác minh	Cách thực hiện	Bảo mật
PUSH (ứng dụng /authenticator)	KH mở trang trên điện thoại → nhập mã ghép 8 số (hết hạn 10 phút, dùng 1 lần) và đặt PIN thiết bị. Từ đó trang tự hiện giao dịch chờ (3 giây/lần) → Duyệt (nhập PIN) hoặc Từ chối	Device token lưu băm; PIN lưu băm; sai PIN 5 lần khóa thiết bị 15 phút; chống dò mã ghép theo IP
TOTP (Google/Microsoft Authenticator)	Nhập secret TOTP đã cấp vào ứng dụng; trong tab KYA nhập mã 6 số cạnh giao dịch chờ	RFC 6238, mã không dùng lại (chống replay), sai 3 lần hủy giao dịch

Giao dịch KYA hiển thị cho khách: loại giao dịch, số tiền, người nhận (che còn 4 số cuối), merchant/quốc gia, Agent nào gửi, **lý do cần xác minh** và thời gian còn lại. Duyệt → hạch toán; Từ chối/hết hạn → không thực hiện, số dư giữ chỗ được nhả.

9. Hướng dẫn vận hành từng cổng

9.1 Cổng Khách hàng (/portal/kh)

Tab	Chức năng
Giao dịch FX	Báo giá và giao dịch FX thủ công của Anti-Bot (giữ nguyên)
AI Agent của tôi	Đăng ký Agent (kèm điều khoản); xem trạng thái, hạn mức hiệu lực; tạm dừng/khôi phục/thu hồi; hạ hạn mức; cấp API key
Authenticator & KYA	Đăng ký TOTP, mã ghép thiết bị; danh sách giao dịch chờ xác minh (tự làm mới) – nhập OTP để Duyệt hoặc Từ chối. Ở demo hiển thị OTP hiện tại để thử nhanh
Thẻ & Người nhận	Thêm thẻ test (kiểm tra Luhn/mạng), token cho Agent, bật/tắt online & quốc tế, khóa tạm; danh sách người nhận tin cậy
Monitor FX / Thanh toán	KPI 90 ngày, biểu đồ quyết định theo ngày, lịch sử giao dịch kèm lý do (KH không thấy điểm ML)
Test Lab	Chạy kịch bản hoặc tự soạn giao dịch như một Agent cho chính mình; nạp số dư demo

9.2 Cổng Chi nhánh (/portal/cn) – Admin và Nhân viên

Tab	Chức năng
Báo giá FX	Cấu hình giá/biên lợi nhuận của Anti-Bot (giữ nguyên)
Duyệt Agent	Hồ sơ đăng ký chờ duyệt (admin: nhập hạn mức, Duyệt/Từ chối; Đình chỉ/Khôi phục/Thu hồi Agent)
Hạn mức Agent	Chọn KH → bảng Trần TSC | Hạn mức CN (nhập) | Hiệu lực cho FX và Thanh toán; vượt trần bị từ chối
Hàng chờ duyệt	Giao dịch REVIEW: chi tiết, điểm, lý do, nhận xét LLM → Duyệt & thực hiện / Từ chối (ghi người duyệt + ghi chú)
Monitor FX / Thanh toán	Dashboard + lịch sử đầy đủ điểm ML/Hành vi/Velocity, lý do, LLM; chọn KH hoặc 'xem toàn bộ phạm vi'
Thẻ Visa/MC	Danh sách thẻ che số; khóa tạm/khóa hẳn (admin)
Hồ sơ hành vi KH	Số dư, suspicion/watchlist, lịch sử online, thói quen FX & Thanh toán; xóa cờ theo dõi (admin)
Test Lab	Chạy kịch bản thay mặt KH trong phạm vi

9.3 Cổng TSC (/portal/hq)

Tab	Chức năng
Giá FX	Cấu hình giá/biên toàn hệ thống của Anti-Bot (giữ nguyên)
Chính sách FX Agent	Ngưỡng điểm, TTL KYA, tỷ giá tham chiếu, trần theo phân khúc, cặp tiền được phép
Chính sách Thanh toán	Ngưỡng điểm, 3DS, MCC/quốc gia/tài khoản bị chặn, trần chuyển tiền/thẻ/online theo phân khúc
Monitor FX / Thanh toán	Giám sát toàn hệ thống; theo KH hoặc toàn bộ
Agent & Kill-switch	Bật/tắt kill-switch (chặn mọi giao dịch Agent kèm lý do, và hủy cả giao dịch đang chờ khi thực hiện); danh sách mọi Agent, đình chỉ/khôi phục
Model & LLM	Trạng thái 2 mô hình, trạng thái LLM (Groq hay luật), huấn luyện lại, đặt lại dữ liệu demo
Test Lab	Chạy kịch bản cho mọi khách

10. Test Lab – kịch bản kiểm thử toàn bộ pipeline

Test Lab chạy giao dịch qua **đúng engine thật** và ghi vào CSDL (nguồn LAB). Mỗi lần chạy kịch bản, Lab tự **lưu trữ kết quả lab cũ** (không tính vào hạn mức/velocity/baseline), hủy KYA lab đang chờ, xóa cờ theo dõi và khôi phục số dư demo, để kết quả lặp lại được. Có thể 'tự soạn giao dịch' bằng JSON và chọn giờ giả lập (0–23).

Mã	Kịch bản	Mô tả / cơ chế	Kỳ vọng
FX-01	Lệnh FX bình thường	Cặp, giá trị, đòn bẩy, giờ đúng thói quen khách → ALLOW	ALLOW
FX-02	Vượt hạn mức / lệnh	Giá trị 1,5× hạn mức hiệu lực → BLOCK (hard policy)	BLOCK
FX-03	Vượt đòn bẩy tối đa	Đòn bẩy = trần + 5 → BLOCK	BLOCK
FX-04	Cặp tiền không được phép	XAUUSD không có trong danh mục → BLOCK	BLOCK
FX-05	Lệnh lớn lúc 3h sáng	Gấp 3,5× thói quen + ngoài giờ → KYA hoặc REVIEW	KYA/REVIEW
FX-06	Vượt ngưỡng bắt buộc KYA	Giá trị ≥ ngưỡng KYA (vẫn trong hạn mức) → chờ xác minh Authenticator	KYA
FX-07	Đòn bẩy tăng đột biến	Đòn bẩy gấp nhiều lần thói quen → KYA	KYA
FX-08	Dồn dập 12 lệnh / 4 phút	Velocity/anti-bot: các lệnh sau bị nâng mức	Tăng dần
FX-09	Cạn hạn mức ngày	Lặp lệnh 40% hạn mức ngày → lệnh thứ 3 bị BLOCK	Tăng dần
FX-10	Ký quỹ vượt số dư	Hạ số dư tiền gửi thanh toán rồi gửi lệnh → BLOCK	BLOCK
FX-11	Agent chưa đăng ký	agent-ghost không có trong Registry → BLOCK	BLOCK
PAY-01	Chuyển tiền thường lệ	Người nhận quen, số tiền trung bình → ALLOW	ALLOW
PAY-02	Mua sắm online thường lệ	Merchant quen, 3DS, nước quen → ALLOW	ALLOW
PAY-03	Vượt hạn mức chuyển tiền / lần	1,2× hạn mức → BLOCK	BLOCK
PAY-04	Vượt số dư tiền gửi thanh toán	Hạ số dư rồi chuyển khoản → BLOCK	BLOCK
PAY-05	Người nhận mới – số tiền lớn	Vượt ngưỡng người nhận mới → KYA	KYA
PAY-06	KH lần đầu giao dịch online	CUST004 (chỉ có lịch sử quầy) – sau khi CN duyệt agent-pay-004 → KYA FIRST_ONLINE	KYA
PAY-07	Tài khoản ngủ đông thức dậy	Dùng CUST003 (110+ ngày không giao dịch) → KYA DORMANT_WAKE	KYA
PAY-08	Agent gửi số thẻ đầy đủ (PAN)	PCI-DSS: chặn + che số thẻ trong log	BLOCK
PAY-09	Agent gửi CVV	Không bao giờ nhận/lưu CVV → BLOCK	BLOCK
PAY-10	MCC bị cấm (cờ bạc 7995)	Danh mục bị chặn toàn hệ thống → BLOCK	BLOCK
PAY-11	Quốc gia rủi ro cao + không 3DS	NG, MCC 5967, CNP không 3DS → KYA/REVIEW (hoặc BLOCK nếu thẻ chưa bật quốc tế)	KYA/REVIEW
PAY-12	Dò thẻ (card testing)	8 giao dịch 5.000đ/10 phút khác merchant → bị nâng mức	Tăng dần
PAY-13	Né hạn mức (structuring)	3 lần chuyển sát 95% hạn mức → bị nâng mức	Tăng dần
PAY-14	Rút gần hết số dư	Chuyển ≈85% số dư → KYA BALANCE_DRAIN	KYA
PAY-15	Agent chưa được duyệt	Dùng agent-pay-004 (PENDING) → BLOCK	BLOCK
PAY-16	Thẻ không có token hợp lệ	tok_fake → BLOCK	BLOCK

Quy trình demo gợi ý đầu-cuối: (1) cust004 → Authenticator: tạo mã ghép + OTP → AI Agent: đăng ký agent-pay mới (hoặc dùng agent-pay-004 đang PENDING) → (2) admin_cn01 → Duyệt Agent → (3) cust004 → cấp API key → gọi API (ví dụ bên dưới) → giao dịch đầu bị KYA (FIRST_ONLINE + thử việc) → (4) mở /authenticator, duyệt bằng PIN → (5) Agent poll thấy EXECUTED → (6) cust001 chạy FX-02, PAY-08 thấy BLOCK → (7) admin_cn01 xem Hàng chờ duyệt, Monitor → (8) hq01 bật kill-switch, chạy lại FX-01 thấy BLOCK.

11. API tham chiếu

11.1 API cho AI Agent (không dùng cookie)

```
POST /agent-api/v1/monitor/action
Authorization: Bearer agk_<prefix>_<secret>
Content-Type: application/json
```

```
# FX
{"domain":"FX","kind":"FX_TRADE","pair":"USDVND","side":"BUY","notional_usd":15000,"leverage":3,"request_id":"abc-1"}

# Chuy□n ti□n
{"domain":"PAY","kind":"TRANSFER","amount_vnd":3000000,"beneficiary_account":"9871234560"}

# Mua s□m online / th□ (ch□ token th□ – KHÔNG g□i s□ th□/CVV)
{"domain":"PAY","kind":"ONLINE_PURCHASE","amount_vnd":2000000,"card_token":"tok_...",
 "merchant_id":"M300","mcc":"5411","country":"VN","three_ds":true}

# Ph□n h□i
200 {"action_id":123,"decision":"KYA","status":"PENDING_KYA","message":"...","kya":{"id":"KYA...","expires_in":180}}
200 {"decision":"ALLOW","status":"EXECUTED"}        403 {"decision":"BLOCK","reason":"Vượt hạn mức..."}
GET /agent-api/v1/actions/123   -> trạng thái mới nh□t (EXECUTED | DENIED_BY_CUSTOMER | EXPIRED ...)
Mã l□i: 400 BAD_REQUEST (payload sai) · 401 UNAUTHORIZED · 429 RATE_LIMITED (120 yêu c□u/phút/Agent)
```

request_id bảo đảm idempotent: gửi lại cùng request_id trả về đúng kết quả cũ (duplicate=true), không tạo giao dịch thứ hai. Agent **không** nhận điểm rủi ro hay lý do nội bộ để tránh dò ngưỡng.

11.2 Danh sách endpoint giao diện (/api/agent, cần đăng nhập + CSRF cho POST)

Endpoint	Method	Đối tượng
/agent-api/v1/actions/<int:aid>	GET	Agent
/agent-api/v1/health	GET	Agent
/agent-api/v1/monitor/action	POST	Agent
/api/agent/actions	GET	Mọi vai trò
/api/agent/actions/<int:aid>	GET	Mọi vai trò
/api/agent/agents	GET	Mọi vai trò
/api/agent/cards/validate	POST	Mọi vai trò
/api/agent/cn/agents/<aid>/status	POST	CN
/api/agent/cn/cards	GET	CN
/api/agent/cn/cards/<card_id>/status	POST	CN
/api/agent/cn/flags/clear	POST	CN
/api/agent/cn/limits	GET,POST	CN
/api/agent/cn/registrations/<aid>/approve	POST	CN
/api/agent/cn/registrations/<aid>/reject	POST	CN
/api/agent/cn/review-queue	GET	CN
/api/agent/cn/review/<int:aid>	POST	CN
/api/agent/hq/killswitch	GET,POST	TSC
/api/agent/hq/model	GET	TSC
/api/agent/hq/model/retrain	POST	TSC
/api/agent/hq/policy/<domain>	GET,POST	TSC
/api/agent/hq/reseed	POST	TSC
/api/agent/lab/custom	POST	Mọi vai trò
/api/agent/lab/run	POST	Mọi vai trò
/api/agent/lab/scenarios	GET	Mọi vai trò
/api/agent/lab/topup	POST	Mọi vai trò
/api/agent/me/agents/<aid>/api-key	POST	KH
/api/agent/me/agents/<aid>/limits	POST	KH
/api/agent/me/agents/<aid>/status	POST	KH
/api/agent/me/agents/register	POST	KH
/api/agent/me/authenticator	GET	KH

Endpoint	Method	Đối tượng
/api/agent/me/authenticator/start	POST	KH
/api/agent/me/authenticator/unpair	POST	KH
/api/agent/me/beneficiaries	GET,POST	KH
/api/agent/me/cards	GET	KH
/api/agent/me/cards	POST	KH
/api/agent/me/cards/<card_id>	POST	KH
/api/agent/me/kya/<kid>/approve	POST	KH
/api/agent/me/kya/<kid>/deny	POST	KH
/api/agent/me/kya/pending	GET	KH
/api/agent/meta	GET	Mọi vai trò
/api/agent/overview	GET	Mọi vai trò
/api/agent/profile	GET	Mọi vai trò
/authapp/decide	POST	Authenticator
/authapp/pair	POST	Authenticator
/authapp/pending	GET	Authenticator
/authenticator	GET	Authenticator

12. Cơ sở dữ liệu (agentmon.db)

Bảng	Nội dung chính
agents	Hồ sơ đăng ký pháp lý: chủ sở hữu, nghiệp vụ, loại giao dịch, hạn mức, phiên bản + mã băm điều khoản, thời điểm/IP đồng ý, người duyệt, hiệu lực, băm API key, thử việc, số lần KH từ chối
actions	Mọi giao dịch/ý định của Agent: số tiền, đối tác, điểm ML/hành vi/velocity/tổng, quyết định, trạng thái, lý do, trigger, nhận xét LLM, người duyệt, nguồn (AGENT_API/LAB/SEED). Payload đã che PAN/CVV
kya	Thử thách KYA: thời hạn, số lần thử, phương thức duyệt (PUSH/TOTP/PORTAL), kết quả
authenticators	Secret TOTP, băm mã ghép, băm device token, băm PIN, số lần sai PIN
accounts	Số dư tiền gửi thanh toán của KH (demo)
cards	Thẻ Visa/MC: BIN6, 4 số cuối, token, băm HMAC, hạn mức, trạng thái, cờ online/quốc tế – KHÔNG có PAN
policies / limits	Chính sách TSC (theo domain) / hạn mức chi nhánh theo CIF
flags	suspicion và watchlist theo KH
trusted_beneficiaries	Người nhận tin cậy do KH khai báo

Ngoài ra mọi thao tác nhạy cảm (đăng ký, duyệt, cấp key, ghép Authenticator, kill-switch, duyệt REVIEW, KYA) đều ghi vào **audit log** của Anti-Bot (JSON Lines → SIEM) kèm người thao tác, IP, mức cảnh báo.

13. Cài đặt, cấu hình, triển khai

```
cd anti-bot-ai-agent-monitor
python -m venv .venv && . .venv/bin/activate
pip install -r requirements.txt
cp .env.example .env        # đặt SECRET_KEY >= 32 ký tự
python app.py               # http://127.0.0.1:5000   (demo)

# Chạy test:   pip install -r requirements-dev.txt && pytest tests -q   (82 test)
# Huấn luyện lại ML:  python -m agentmon.train_cli
# Sinh lại PDF:       python tools/make_manual.py
# Production:  gunicorn -w 4 -b 0.0.0.0:8000 'app:create_app()'   (sau reverse proxy TLS)
```

Biến môi trường	Ý nghĩa
SECRET_KEY	Bắt buộc, ≥ 32 ký tự (phiên, CSRF)
PRICING_ENVIRONMENT	demo | production. Production tắt Test Lab và nút reseed (trừ khi AGENTMON_LAB=1)
AGENTMON_DB	Đường dẫn SQLite; production dùng PostgreSQL
AGENTMON_MODEL_DIR	Thư mục mô hình .joblib
CARD_VAULT_KEY	Khóa HMAC băm số thẻ – bắt buộc đặt ở production, lưu trong KMS/HSM
LLM_PROVIDER / GROQ_API_KEY / LLM_MODEL / LLM_MODE / LLM_TIMEOUT	Bật Groq (groq) hoặc bộ phản biện luật (mock); chế độ gray | always | off
REDIS_URL	Rate-limit/phiên dùng chung nhiều worker (như Anti-Bot gốc)

Bật LLM Critic (Groq)

```
LLM_PROVIDER=groq
GROQ_API_KEY=gsk_...
LLM_MODEL=llama-3.3-70b-versatile
LLM_MODE=gray      # gọi □ vùng xám / có trigger; always = mọi giao dịch; off = t□t
```

Chỉ dữ liệu đã tối thiểu hóa được gửi tới LLM (không PAN, không tên, không số tài khoản, số tiền làm tròn bậc). Không có khóa hoặc Groq lỗi/timeout → tự động dùng bộ phản biện luật; hệ thống vẫn quyết định bình thường.

14. Bảo mật đã áp dụng

- Phiên/CSRF/rate-limit/chống bot của Anti-Bot áp dụng cho toàn bộ /api/agent; API Agent và Authenticator có xác thực Bearer, rate-limit và khóa IP khi sai khóa nhiều lần.
- Phân quyền theo vai trò và phạm vi KH ở mọi endpoint; KH không xem được dữ liệu KH khác; nhân viên chỉ thấy KH được phân công; chỉ Admin duyệt/đổi hạn mức.
- API key, device token, PIN, mã ghép: chỉ lưu băm (SHA-256); so sánh hằng thời gian; key hiển thị một lần.
- OTP TOTP không dùng lại; thao tác nhạy cảm (đăng ký Agent, cấp key) yêu cầu OTP.
- Xử lý đồng thời: engine tuần tự hóa kiểm tra hạn mức + ghi nhận; hạch toán kiểm tra lại số dư/Agent/kill-switch tại thời điểm thực hiện (chống TOCTOU).
- Giữ chỗ số dư và hạn mức ngày cho giao dịch chờ KYA/REVIEW để không thể 'né' bằng cách gửi dồn lệnh chờ.
- Dữ liệu thẻ: không PAN/CVV trong CSDL, log hay audit; payload được che trước khi lưu.
- Giao diện: mọi chuỗi từ server được escape; CSP của Anti-Bot giữ nguyên.

15. Giới hạn của bản demo và lộ trình lên production

Hạng mục	Hiện trạng demo	Cần làm khi production
CSDL	SQLite 1 máy, khóa tiến trình đơn	PostgreSQL + khóa dòng (SELECT … FOR UPDATE) cho cộng dồn hạn mức/số dư; sao lưu
Số dư & hạch toán	Bảng accounts mô phỏng; FX chỉ giữ ký quỹ	Tích hợp core banking/ledger, đối soát; mô hình vị thế FX đầy đủ (đóng vị thế, mark-to-market)
Thẻ	Token hóa nội bộ + số thẻ test	Card vault/HSM đạt PCI-DSS, network tokenization, 3DS thật từ issuer processor
Authenticator	Web giả lập + TOTP; push bằng polling	Ứng dụng di động thật, push FCM/APNs, sinh trắc học, gắn thiết bị bằng khóa bất đối xứng
Pháp lý	Mẫu điều khoản + lưu bằng chứng đồng ý	Pháp chế duyệt điều khoản; chữ ký số/eKYC; lưu trữ theo quy định
ML	Huấn luyện trên dữ liệu tổng hợp	Huấn luyện bằng lịch sử thật + nhãn gian lận; giám sát drift; quy trình phê duyệt mô hình (MRM)

Hạng mục	Hiện trạng demo	Cần làm khi production
Danh sách cấm	Danh sách MCC/quốc gia/tài khoản mẫu	Kết nối danh sách trừng phạt/AML chính thức của ngân hàng
Giám sát vận hành	Audit log JSONL	Đẩy SIEM, cảnh báo webhook, dashboard SLA, RBAC chi tiết, 4-mắt cho thay đổi chính sách TSC

Tài liệu và mã nguồn này là hệ thống **demo/pilot** phục vụ kiểm thử kiến trúc và nghiệp vụ. Số thẻ, danh sách cấm vận, ngưỡng và điều khoản pháp lý chỉ là ví dụ – cần được các bộ phận tuân thủ, pháp chế và an toàn thông tin của ngân hàng thẩm định trước khi dùng với dữ liệu thật.

Phụ lục A – Cấu trúc thư mục

```
anti-bot-ai-agent-monitor/
├── app/                 Anti-Bot g□c (đăng nhập, guard, portal, giao dịch FX, mock_db)
├── agentmon/            MODULE AI AGENT MONITOR
│   ├── engine.py        pipeline quy□t định + hạch toán + review
│   ├── policy.py        chính sách TSC, hạn mức CN, hạn mức hiệu lực
│   ├── features.py      feature, đi□m hành vi, velocity, trigger KYA
│   ├── ml.py            Isolation Forest + dữ liệu hu□n luyện t□ng hợp
│   ├── critic.py        LLM Critic (Groq) + bộ ph□n biện luật
│   ├── kya.py           Authenticator, th□ thách KYA
│   ├── registry.py      đăng ký Agent pháp lý, API key
│   ├── cards.py         Visa/MC, Luhn, token hóa, che PAN/CVV
│   ├── seed.py          dữ liệu demo (s□ dư, th□, lịch s□, Agent)
│   ├── lab.py           kịch b□n Test Lab
│   ├── api.py           /api/agent/*      agent_api.py  /agent-api, /authapp
│   └── reports.py       dashboard, lịch s□, h□ sơ hành vi
├── templates/ static/   3 c□ng có tab + trang authenticator
├── models/              iforest_fx.joblib, iforest_pay.joblib
├── tests/               82 test (test_agentmon.py: 20 test mới)
├── tools/make_manual.py sinh PDF này
└── docs/HUONG_DAN_VAN_HANH.pdf
```